DeepGuard

Compliance Engine

Autonomous AI-Powered Security Compliance Checker

Business Case · Commercial Viability · Technical Architecture

Document Details

Version:	5.0
Date:	April 2026
Classification:	Confidential
Prepared by:	DeepGuard Product Team

Table of Contents

1. Executive Summary

DeepGuard Compliance Engine is a fully autonomous, AI-powered compliance platform that analyses source code repositories *and* cloud infrastructure configurations against security and AI governance policy frameworks, then generates professional audit-grade PDF reports with remediation guidance.

In April 2026, Anthropic revealed that its Claude Mythos model had autonomously discovered thousands of previously unknown zero-day vulnerabilities in every major operating system and browser — many of them decades old, and over 99% still unpatched. Anthropic subsequently withheld general release of Mythos and launched **Project Glasswing**, a $100M defensive consortium with Amazon, Apple, Google, Microsoft, Cisco, CrowdStrike, and JPMorgan Chase, to patch critical software before these findings can be weaponised. A public vulnerability disclosure report is expected in July 2026.

This moment represents the most significant shift in enterprise security posture since Log4Shell — except the scale and depth of exposure is orders of magnitude greater. Every enterprise CISO and CIO must now operate under the assumption that their proprietary codebases and cloud environments contain critical, AI-discoverable vulnerabilities that traditional scanning tools have never found and will never find.

DeepGuard is the answer for the enterprise. Project Glasswing scans critical open-source infrastructure — not your proprietary application code, not your cloud configuration, not your custom business logic. DeepGuard fills that gap: applying the same depth of AI-powered reasoning to enterprise source code and cloud environments, within the customer's own security perimeter.

Key value propositions:

- Unified compliance posture across source code AND cloud infrastructure in a single report
- Applies Mythos-class AI reasoning depth to proprietary enterprise codebases — privately, inside the customer's VPC
- Custom policy document ingestion — map any written policy, regulation, or internal standard to code and config
- LLM-powered reasoning understands compliance intent, not just pattern rules
- Audit-ready PDF evidence reports accepted by external auditors
- Zero code or configuration data leaves the customer perimeter in private deployment mode
- Cloud-agnostic: runs natively on AWS, Azure, GCP, or air-gapped private data centres
- Covers AI governance frameworks: ISO 42001, EU AI Act, OWASP LLM Top 10, NIST AI RMF
- Open-source LLM support for fully air-gapped, data-sovereign deployments

The total addressable market across application security testing, GRC software, cloud security posture management, and AI governance tooling exceeds **$130 billion and is accelerating sharply** in the post-Mythos era. The serviceable market for enterprises requiring AI-native, cross-cloud, data-residency-compliant security tooling is approximately **$8–10 billion** — and growing faster than any prior estimate, driven by a wave of regulatory mandate convergence and the Mythos-triggered recognition that the existing vulnerability surface is vastly larger than any organisation currently knows.

2. The Mythos Inflection Point: A New Security Paradigm

> This section describes the Anthropic Claude Mythos findings and Project Glasswing announcement of April 2026, and their direct implications for enterprise security spending and the DeepGuard market opportunity.

2.1 What Mythos Revealed

In March 2026, a data leak revealed the existence of **Claude Mythos Preview**, Anthropic's most capable AI model. In April 2026, Anthropic confirmed and publicly disclosed the model's capabilities: Mythos is able to autonomously discover and exploit software vulnerabilities at a scale and depth that no prior tool — human or automated — has achieved.

Key findings from Anthropic's disclosure:

- Mythos identified **thousands of zero-day vulnerabilities** — previously completely unknown to software vendors — in every major operating system and every major web browser
- Many vulnerabilities are **ten to twenty years old**; the oldest found so far is a 27-year-old bug in OpenBSD
- Mythos **fully autonomously** identified and exploited a 17-year-old remote code execution vulnerability in FreeBSD allowing root access with no human involvement after the initial request
- Engineers at Anthropic **with no formal security training** asked Mythos to find remote code execution vulnerabilities overnight and woke to a complete, working exploit
- **Over 99% of vulnerabilities found by Mythos remain unpatched** as of disclosure

Anthropic did not explicitly train Mythos to specialise in software exploitation. These capabilities are described as a *downstream consequence of general improvements in AI reasoning and software engineering capabilities* — which means every future AI model generation will be at least as capable, and likely more so.

Anthropic chose not to release Mythos Preview to the general public, citing cybersecurity concerns. This is the first major AI model withheld from release primarily on security grounds.

(Sources: Anthropic red.anthropic.com/2026/mythos-preview; Fortune, 26 March 2026; Axios, 7 April 2026)

2.2 Project Glasswing — Defensive Response at Scale

On 8 April 2026, Anthropic launched **Project Glasswing** — a coordinated defensive consortium with twelve founding partners:

Amazon Web Services · Apple · Broadcom · Cisco · CrowdStrike · Google · JPMorgan Chase · the Linux Foundation · Microsoft · NVIDIA · Palo Alto Networks · Anthropic

Anthropic committed **$100 million in Mythos usage credits** across this effort, plus $4 million in direct donations to open-source security organisations. The consortium's goal is to use Mythos Preview to find and patch critical software vulnerabilities before attackers can weaponise the same capabilities.

A **public vulnerability disclosure report** is expected in **July 2026**, which will trigger what security analysts describe as a high-volume patch cycle across operating systems, browsers, cryptography libraries, and major infrastructure software simultaneously.

(Sources: Anthropic glasswing; CSO Online; Simon Willison; IANS Research)

2.3 Why Glasswing Does Not Solve the Enterprise Problem

Project Glasswing addresses critical open-source infrastructure — the foundational software layers that underpin the internet. It does **not** address:

- **Proprietary enterprise application code** — the custom business logic, APIs, authentication flows, and data handling code that runs inside every bank, hospital, insurer, and government agency
- **Enterprise cloud configurations** — the IAM policies, network configurations, storage settings, and security controls that each enterprise has configured individually
- **Custom integrations and microservices** — the thousands of internal services each enterprise has built on top of open-source foundations
- **LLM-integrated applications** — the AI-enabled systems enterprises have rushed to build, each introducing novel vulnerability classes that Glasswing's scope does not include

The implication is stark: **Glasswing will patch the foundation, but every enterprise's structure built on that foundation remains unscanned, unexplored, and — by the logic of Mythos's findings — almost certainly riddled with AI-discoverable vulnerabilities that traditional tools have never found.**

JPMorgan Chase CEO Jamie Dimon stated after the Mythos announcement: *"Mythos reveals a lot more vulnerabilities for cyberattacks than we previously understood."* This sentiment, from the head of the world's largest bank, captures the enterprise CISO and CIO mindset precisely.

(Source: CNBC, 14 April 2026)

2.4 The Exploit Gap Has Closed — The Implications for Every Enterprise

The Council on Foreign Relations identified six ways Mythos represents an inflection point for global security. For enterprise security specifically, the most critical consequence is the **collapse of the exploit gap**:

Historically, the time between a vulnerability being discovered and being weaponised into a working exploit was measured in **weeks to months** — enough time for a patch cycle to provide meaningful protection. Mythos collapses this to **hours or overnight**. The IANS Faculty warns that organisations should "assume near-immediate weaponisation" once vulnerabilities are known.

This has three direct consequences for enterprises:

1. Existing vulnerability scanning tools are now provably inadequate. If Mythos found thousands of critical vulnerabilities that survived 27 years of human review, security and code analysis tools, it is mathematically certain that enterprise codebases contain similar classes of vulnerability that existing SAST tools, SCA tools, and CSPM tools have never detected. Every CISO must now assume their vulnerability surface is vastly larger than their current tooling indicates.

2. Compliance posture assessments are retrospectively incomplete. A SOC 2, ISO 27001, or PCI-DSS audit conducted with pre-Mythos tools attested to security posture against a known vulnerability universe. That universe has just expanded by an unknown but enormous factor. Regulators, auditors, and boards will demand re-assessment using AI-powered tools.

3. The patching regime must be fundamentally restructured. DarkReading, Help Net Security, and VentureBeat all report that the post-Mythos era requires organisations to compress patch timelines from weeks to near-real-time, and to build continuous AI-assisted scanning into their development pipeline — not as a periodic audit but as a permanent, automated control.

(Sources: CFR; DarkReading; VentureBeat; Help Net Security; Knostic AI; Cloud Security Alliance Mythos CISO Playbook)

2.5 The DeepGuard Opportunity Created by Mythos

The Mythos announcement creates a **step-change demand event** for AI-powered security scanning of proprietary enterprise code and infrastructure. The market dynamics change in three specific ways:

Urgency: CISOs and CIOs who were evaluating AI security tooling over an 18-month horizon are now in emergency procurement mode. The Cloud Security Alliance's CISO Mythos Playbook explicitly recommends organisations "immediately deploy AI-assisted code and configuration analysis tools to identify vulnerabilities your current tooling cannot see."

Budget availability: The Mythos announcement will unlock emergency security budgets at enterprises that had previously deferred AI security tooling investment. Board-level concern — illustrated by Jamie Dimon's public statement — translates directly to approved security spend.

Regulatory acceleration: The July 2026 Glasswing public report lands within weeks of the EU AI Act Article 9 risk management enforcement deadline. Regulators who were already expecting AI governance evidence will now expect demonstrable evidence that enterprise AI-powered code scanning has been deployed. Organisations that cannot show this will face material audit findings.

DeepGuard is the only platform positioned to meet this demand in the enterprise context:

- It applies Mythos-class reasoning depth (via Bedrock Claude, Azure OpenAI, or open-source equivalents) to proprietary code
- It operates within the customer's VPC — no proprietary code leaves the perimeter
- It supports air-gapped deployment for organisations in regulated sectors that cannot connect to any external AI API
- It generates the audit-ready evidence that regulators and boards will demand in the post-Mythos era
- It scans cloud infrastructure configuration alongside code — the combined surface that Glasswing does not address

2.6 The Odysseus Narrative — The Intelligence Engine at DeepGuard's Core

Anthropic named their model **Mythos** — the Greek word for *story*; the primordial tales in which gods and heroes reveal the hidden truths of the world. The parallel is exact: the vulnerabilities Mythos discovered are not new dangers. They are primordial ones, woven into software from its very beginning — hidden for decades, only now revealed by an intelligence capable of seeing what human review could not.

In Greek mythology, when Odysseus needed to understand the full danger of his journey home, he descended to the Underworld to consult **Tiresias** — the blind prophet who reads what is written in the laws of fate. Unlike Cassandra's audience (who heard the truth and dismissed it) or the citizens of Troy (who ignored Laocoon's warning about the Wooden Horse), **Odysseus listened**. He returned from the Underworld knowing exactly what he faced — and prepared accordingly.

He did not confront every danger with brute force. He used *m■tis* — cunning intelligence: structural thinking, careful preparation, and the wisdom to constrain himself where willpower would fail. He tied himself to the mast rather than trusting he could resist the Sirens by strength of will alone. He arrived at his own palace in disguise — unseen, operating inside the perimeter — and revealed himself only when the moment was right.

DeepGuard's central agentic reasoning engine is named the Odysseus Engine in recognition of this exact disposition:

- **It was warned** — Anthropic's Mythos has revealed that hidden vulnerabilities exist at scale in every codebase, just as Tiresias warned Odysseus of the dangers on his path home
- **It listens** — unlike rule-based tools that pattern-match without understanding, the Odysseus Engine applies deep AI reasoning (*m■tis*, not brute force) to compliance analysis
- **It uses structural constraints** — VPC-native and air-gapped deployment means code never leaves the customer's perimeter by architectural design, not by policy promise — Odysseus tied to the mast
- **It operates inside the perimeter** — deployed within the customer's own environment, invisible to the outside world, like Odysseus entering his own palace in disguise

- **It navigates every danger** — from code vulnerabilities to IaC misconfigurations to live cloud posture gaps, the Odysseus Engine coordinates a crew of specialist agents, each named for the mythological figure whose nature it embodies

The mythology did not choose DeepGuard. Anthropic named their model Mythos — and in doing so, set the context. Every enterprise security team now faces the same challenge Odysseus faced: warned of dangers ahead, navigating a hostile landscape, needing to reach home safely with their proprietary code intact. The Odysseus Engine is built for exactly this journey.

> *"I am Odysseus, son of Laertes, known among men for stratagems of every kind, and my fame extends to the heavens."* — Homer, Odyssey IX.19–20

---

3. Problem Statement

3.1 The Compliance Burden on Engineering Teams

Security compliance audits against frameworks such as PCI-DSS, OWASP ASVS, and ISO 27001 are manual, expensive, and inconsistent. Security engineers report spending 60–70% of audit cycles on mechanical policy-to-code and policy-to-infrastructure mapping — a task that is repetitive, error-prone, and adds no analytical value. With the addition of emerging AI governance mandates (ISO 42001, EU AI Act), organisations building AI-enabled products now face a compounding compliance burden for which no purpose-built tooling exists.

In the post-Mythos environment, this burden is further amplified: compliance programmes must now demonstrate not only that known control requirements are met, but that AI-powered deep analysis has been applied to the full vulnerability surface — a capability that traditional compliance tooling is structurally unable to provide.

3.2 The Data Residency Blocker

Sending proprietary source code or cloud configuration data to any external large language model (LLM) API — including OpenAI, Anthropic, Google, or any other cloud-hosted provider — creates material legal and regulatory risk for enterprises:

- **GDPR / PDPA**: Source code and infrastructure topology constitute proprietary business data; transfer outside approved jurisdictions requires adequate safeguards
- **Financial sector regulations**: MAS TRM (Singapore), FFIEC (US), DORA (EU) impose strict controls on third-party data sharing and cloud service provider risk
- **Healthcare regulations**: HIPAA Business Associate Agreements do not extend to general-purpose LLM API providers
- **IP and trade secret law**: Transmitting unreleased source code or internal infrastructure configurations to a third-party provider may constitute a trade secret disclosure
- **National security / defence**: Classified and controlled unclassified information (CUI) cannot be processed on commercial cloud AI APIs

Critically, the Mythos revelation intensifies this concern: **enterprises now need to apply Mythos-class AI reasoning to their proprietary code, but cannot send that code to Anthropic or any other external AI provider.** DeepGuard's VPC-native and air-gapped deployment modes resolve this tension entirely.

3.3 The Multi-Cloud Blind Spot

Modern enterprise workloads span multiple cloud providers and often include on-premises systems. Current compliance tooling is provider-native:

- AWS Security Hub only assesses AWS resources
- Microsoft Defender for Cloud only assesses Azure resources
- Google Security Command Center only assesses GCP resources
- None of these tools can correlate compliance posture across providers in a single unified report
- None can scan application source code alongside infrastructure configuration
- None support custom policy document ingestion
- None operate in air-gapped or private data centre environments

Enterprises running hybrid or multi-cloud architectures — which represent **87% of enterprise cloud deployments** (Flexera, 2024) — have no single tool that provides a unified compliance view across their entire estate.

3.4 The Post-Mythos Vulnerability Surface Reality

The most critical problem statement of all, in April 2026, is this: **every organisation must now assume its codebase contains critical, AI-discoverable vulnerabilities that its current security tooling has never detected and never will detect.**

The evidence from Mythos is unambiguous:

- Vulnerabilities surviving 10–27 years of continuous security review by professional teams
- Flaws in every major OS and browser — the most heavily scrutinised software in the world
- Zero-day exploits generated overnight by engineers with no formal security training

If this is true of the world's most-reviewed software, the vulnerability density in the average enterprise's proprietary application code — which receives a fraction of that scrutiny — is almost certainly higher. Security teams must deploy AI-powered scanning now, not as an aspirational future state but as an immediate operational requirement.

3.5 Gaps in Existing Tooling

Current static analysis tools (Snyk, Checkmarx, Veracode, SonarQube) address syntax-level vulnerabilities but fail to:

- Apply deep AI reasoning to understand vulnerability *intent* and *context* across the full codebase
- Map code or infrastructure implementation to written policy *intent*
- Ingest and reason against custom, organisation-specific security policies
- Produce executive-ready narrative reports usable as audit evidence
- Support AI system governance frameworks (ISO 42001, EU AI Act, OWASP LLM Top 10)
- Scan cloud infrastructure configurations alongside application code in a unified workflow
- Operate across multiple cloud providers or in air-gapped environments
- Find the classes of subtle, deep vulnerability that Mythos has demonstrated exist at scale

---

4. Proposed Solution

DeepGuard Compliance Engine

An autonomous agentic system that accepts any combination of:

- A source code repository (GitHub, GitLab, Bitbucket, or ZIP upload)
- Cloud infrastructure configurations (AWS, Azure, GCP, Terraform, CloudFormation, Bicep, Pulumi)
- Live cloud environment connections (read-only API access to scan running configurations)
- A security policy document (predefined framework or custom upload)

And produces a professional PDF compliance report with:

- Unified findings across source code AND infrastructure layers
- Per-requirement pass/fail/partial status with precise evidence references
- Severity-prioritised remediation playbook with code and configuration fixes
- Executive summary with overall compliance posture and risk score
- Audit trail suitable for submission to external auditors and regulators

4.1 Deployment Options

Mode	Description	Cloud	Best For
SaaS (Managed)	Hosted by DeepGuard	Any (via API)	SMEs, startups, non-regulated
Private Cloud — AWS	Deployed into customer AWS VPC	AWS	Banks, healthcare, government
Private Cloud — Azure	Deployed into customer Azure VNet	Azure	Microsoft-centric enterprises
Private Cloud — GCP	Deployed into customer GCP VPC	GCP	Cloud-native, AI-first companies
Air-Gapped / On-Prem	Self-contained Kubernetes + open-source LLM	None	Defence, classified, sovereign cloud

4.2 Scanning Scope

DeepGuard unifies compliance scanning across all three layers of a modern system:

Layer 1 — Application Code: Source code repositories, dependencies, APIs, authentication flows, data handling logic, LLM integration patterns, AI model usage

Layer 2 — Infrastructure as Code (IaC): Terraform, CloudFormation, AWS CDK, Bicep, Pulumi, Ansible, Kubernetes manifests — policy compliance before deployment

Layer 3 — Live Cloud Configuration: Running cloud resources scanned via read-only API — IAM policies, network topology, storage configuration, encryption settings, logging and monitoring posture

---

5. Market Opportunity

5.1 Market Sizing with Citations

Application Security Testing (AST) Market

The global application security testing market was valued at **$9.19 billion in 2023** and is projected to reach **$28.4 billion by 2030**, growing at a CAGR of 17.5%. The Mythos announcement is expected to materially

accelerate this growth as organisations rush to deploy AI-powered scanning.

(Source: Grand View Research, "Application Security Testing Market Size Report, 2030", 2023)

Cloud Security Posture Management (CSPM) Market

The CSPM market was valued at **$4.2 billion in 2023** and is projected to reach **$14.6 billion by 2028**, at a CAGR of 28.3%.

(Source: MarketsandMarkets, "Cloud Security Posture Management Market — Global Forecast to 2028", 2023)

Governance, Risk & Compliance (GRC) Software Market

The GRC software market was valued at **$47.6 billion in 2023**, projected to reach **$105.1 billion by 2030** at a CAGR of 11.9%.

(Source: MarketsandMarkets, "GRC Platform Market — Global Forecast to 2030", 2024)

AI Governance & Trustworthy AI Tools Market

Valued at approximately **$1.8 billion in 2024**, projected to reach **$13.9 billion by 2030** at a CAGR of 40.2%, accelerated by EU AI Act and ISO 42001 adoption.

(Source: IDC, "Worldwide AI Governance and Responsible AI Software Forecast, 2025–2030", 2024)

DevSecOps Market

Valued at **$6.1 billion in 2023**, projected to reach **$45.9 billion by 2031** at a CAGR of 28.4%.

(Source: Allied Market Research, "DevSecOps Market by Component and Deployment Mode", 2023)

Generative AI in Cybersecurity

Valued at **$2.4 billion in 2024**, forecast to reach **$17.4 billion by 2030** at a CAGR of 38.9%.

(Source: MarketsandMarkets, "Generative AI in Cybersecurity Market — Global Forecast to 2030", 2024)

Multi-Cloud Management Market

Valued at **$8.9 billion in 2023**, projected to reach **$28.7 billion by 2028** at a CAGR of 26.4%, driven by 87% of enterprises operating multi-cloud strategies.

(Source: MarketsandMarkets, "Multi-Cloud Management Market", 2023; Flexera, "State of the Cloud Report 2024")

5.2 The Mythos-Driven Demand Multiplier

The standard market sizing above was established before the Mythos announcement. The Mythos event represents a discrete demand shock that materially increases the near-term addressable market for AI-powered security scanning tools across all segments above.

Analyst precedent from comparable events:

- **Log4Shell (December 2021)**: Enterprise security software spending increased 34% in the quarter following disclosure, with vulnerability management and SAST tools seeing the sharpest spikes
- **SolarWinds (December 2020)**: Triggered a multi-year increase in supply chain security and code integrity spending
- **EternalBlue / WannaCry (2017)**: Drove a decade of increased patch management investment

Mythos is qualitatively different from all prior events because it is not a single disclosed vulnerability but a **structural capability revelation** — the demonstration that an entire *class* of previously undetectable

vulnerability exists at scale in virtually every enterprise codebase. The Cloud Security Alliance's CISO Mythos Playbook describes this as triggering "multiple Log4j-level events per month" once the July 2026 Glasswing disclosures begin.

The IANS Research assessment is explicit: *"Security organizations will likely be overwhelmed by the need to apply patches and respond to AI-discovered vulnerabilities, with the storm of vulnerability disclosures from Project Glasswing being the first of many large waves."*

DeepGuard's positioning at the intersection of AI-powered code analysis, compliance reporting, and data-sovereign deployment means it captures spending across all accelerating segments simultaneously.

5.3 Market Summary

Segment	2024 Value	2030 Projection	CAGR	Mythos Impact
Application Security Testing	$9.19B	$28.4B	17.5%	High acceleration
Cloud Security Posture Mgmt	$4.2B	$14.6B	28.3%	High acceleration
GRC Software	$47.6B	$105.1B	11.9%	Moderate acceleration
AI Governance Tools	$1.8B	$13.9B	40.2%	High acceleration
DevSecOps	$6.1B	$45.9B	28.4%	High acceleration
Gen AI in Cybersecurity	$2.4B	$17.4B	38.9%	Very high acceleration
Multi-Cloud Management	$8.9B	$28.7B	26.4%	Moderate acceleration
Total Addressable Market	**~$80B**	**~$240B**	—	All segments accelerating

Serviceable Addressable Market (SAM): ~$8–10 billion by 2027, with near-term acceleration driven by Mythos-triggered emergency procurement.

5.4 Regulatory Tailwinds Accelerating Demand

- **EU AI Act (enforcement 2024–2026)**: Mandatory conformity assessments for high-risk AI systems; Article 9 risk management deadline coincides with July 2026 Glasswing disclosures
- **ISO 42001 (published Dec 2023)**: First international AI management system standard
- **MAS TRM (Singapore, revised 2021)**: Mandatory technology risk controls for Singapore financial institutions
- **PCI-DSS v4.0 (mandatory March 2025)**: New software security requirements in Requirement 6
- **DORA (EU, effective Jan 2025)**: Digital operational resilience for EU financial entities
- **SEC Cybersecurity Rule (2023)**: US public companies must disclose material cybersecurity risks
- **NIST CSF 2.0 (2024)**: Explicitly addresses AI-era supply chain and cloud security

---

6. Competitive Landscape & Differentiation from Native Cloud Tools

6.1 Why AWS Security Hub, Microsoft Defender, and Google SCC Are Not Enough

Native cloud security tools provide valuable signals within their own ecosystems but are fundamentally limited for enterprise compliance requirements — and are entirely unequipped for the post-Mythos era.

AWS Security Hub — Specific Limitations

AWS Security Hub aggregates findings from AWS services (GuardDuty, Inspector, Macie, Config) and maps them to standards including CIS AWS Foundations, PCI-DSS, and NIST SP 800-53. However:

- **AWS-only scope**: Cannot assess Azure, GCP, or on-premises resources
- **No source code analysis**: Operates entirely at the infrastructure layer — cannot assess whether application code implements the controls that infrastructure enforces
- **No custom policy documents**: Cannot ingest bespoke organisational policies or regulator-issued guidance
- **No LLM reasoning**: Finding generation is rule-based; cannot reason about policy *intent* or detect Mythos-class deep vulnerabilities
- **No remediation code generation**: Findings are described in text; no IaC patches or code diffs generated
- **No audit-narrative reports**: Produces dashboards and JSON; not a document for external auditors
- **Not VPC-deployable as standalone**: Cannot run air-gapped or in classified environments
- **No AI governance framework support**: ISO 42001, EU AI Act, OWASP LLM Top 10 are entirely absent
- **Cannot find Mythos-class vulnerabilities**: Rule-based matching is definitionally unable to find the classes of subtle, deep vulnerability that Mythos demonstrated — the entire category of previously undetectable flaws

Microsoft Defender for Cloud — Specific Limitations

- Azure resources only; no cross-cloud; no source code analysis
- No custom policy ingestion; no LLM reasoning; no narrative reports
- Cannot be deployed outside Azure platform

Google Security Command Center — Specific Limitations

- GCP resources only; no cross-cloud; no source code analysis
- No custom policy ingestion; no AI governance frameworks
- Premium tier required; no narrative outputs

6.2 DeepGuard vs. Native Cloud Tools — Feature Matrix

Capability	AWS Security Hub	MS Defender	Google SCC	DeepGuard
Source code scanning	No	No	No	**Yes**
IaC scanning	Partial (Config)	Partial	No	**Yes**
Live cloud config scanning	AWS only	Azure only	GCP only	**AWS+Azure+GCP+On-prem**
Custom policy document ingestion	No	No	No	**Yes**
LLM-powered reasoning	No	No	No	**Yes**
Mythos-class deep vulnerability detection	No	No	No	**Yes**
Audit-ready narrative PDF report	No	No	No	**Yes**

Capability	AWS Security Hub	MS Defender	Google SCC	DeepGuard
Remediation code/config generation	No	No	No	**Yes**
ISO 42001 / EU AI Act	No	No	No	**Yes**
OWASP LLM Top 10	No	No	No	**Yes**
VPC / air-gapped deployment	No	No	No	**Yes**
Multi-cloud unified posture	No	No	No	**Yes**
Open-source LLM support	No	No	No	**Yes**

6.3 Broader Competitive Matrix

Competitor	Core Capability	Cloud-Agnostic	Source Code	LLM Reasoning	Custom Policy	Audit PDF
Snyk	SAST, SCA, IaC	Partial	Yes	No	No	No
Checkmarx	Enterprise SAST	No	Yes	No	Limited	Basic
Veracode	SAST + Compliance	No	Yes	No	No	Yes
SonarQube Enterprise	Code quality + SAST	Self-hosted	Yes	No	No	No
Prisma Cloud (Palo Alto)	CSPM + CWPP	Yes	Partial	No	Limited	Limited
Wiz	CSPM + CNAPP	Yes	No	No	No	No
Orca Security	CSPM agentless	Yes	No	No	No	Limited
DeepGuard	**Policy-to-code + infra AI**	**Yes**	**Yes**	**Yes**	**Yes**	**Yes**

6.4 The Post-Mythos Competitive Moat

DeepGuard's moat deepens specifically because of Mythos for five reasons:

Rule-based SAST is now demonstrably inadequate: Mythos proved that existing rule-based tools miss entire classes of critical vulnerability. Only LLM-powered reasoning can find what DeepGuard finds. This is no longer a marketing claim — it is an empirically demonstrated fact.

VPC-native is now a hard requirement, not a preference: As enterprises race to apply Mythos-class scanning to their proprietary code, they face the same data residency constraint as always — they cannot send that code to any external AI API. DeepGuard is the answer.

Open-source LLMs close the air-gap: For organisations in classified or sovereign environments that cannot even connect to Bedrock or Azure OpenAI, DeepGuard's open-source LLM support (Section 12) is the only path to AI-powered security scanning. No competitor offers this.

Audit-ready output is now a regulatory requirement: Post-Mythos, regulators will require evidence of AI-powered scanning. DeepGuard produces that evidence in the format auditors need. A dashboard screenshot from AWS Security Hub does not meet this bar.

Multi-cloud scope matches the real attack surface: Mythos found vulnerabilities in foundational software. The attack surface in an enterprise spans code, IaC, and live cloud config across multiple providers. DeepGuard is the only tool that covers all of it.

---

7. Business Model & Pricing

7.1 SaaS (Managed Cloud)

Hosted on DeepGuard's multi-tenant AWS infrastructure. Source code and configuration data are processed ephemerally — deleted within 1 hour of analysis completion. SOC 2 Type II certified. Regional options: Singapore (ap-southeast-1), EU (eu-west-1), US East (us-east-1).

All prices in Singapore Dollars (SGD).

Plan	Price	Inclusions
Starter	SGD 680/month	5 repositories, OWASP Top 10 + ASVS, 3 users, 10 reports/month
Professional	SGD 3,000/month	25 repos, all standard frameworks, 15 users, CI/CD integration, cloud config scanning (1 account)
Business	SGD 8,800/month	100 repos, custom policy upload, 50 users, 3 cloud accounts, API access, Slack/Jira integration
Enterprise SaaS	SGD 20,000/month	Unlimited repos, dedicated tenant, unlimited cloud accounts, custom SLA, SSO/SAML, dedicated CSM

7.2 Private Cloud (VPC Deployment)

Deployed as a self-contained Terraform/Helm stack into the customer's own cloud account or on-premises Kubernetes environment. The vendor never has access to the customer environment or data.

All prices in Singapore Dollars (SGD).

Tier	Annual License	Includes
Private Cloud Standard	SGD 115,000/year	Single cloud provider, 50 repos/month, 3 frameworks, 20 users
Private Cloud Professional	SGD 200,000/year	Single cloud, unlimited repos, all frameworks including AI governance, 100 users, CI/CD SDK
Private Cloud Multi-Cloud	SGD 300,000/year	Up to 3 cloud providers or 1 provider + on-prem, all frameworks, unlimited users
Air-Gapped / On-Prem	SGD 380,000/year	Self-hosted open-source LLM, Kubernetes on-prem, all frameworks, unlimited users, 24/7 support

Tier	Annual License	Includes
Professional Services	SGD 2,000/day	Deployment, framework customisation, cloud connector setup, auditor liaison
Framework Maintenance	SGD 25,000/year	Quarterly updates, new standards additions, open-source model upgrades

7.3 MSSP / Partner Channel

Tier	Price	Revenue Share
Partner Standard	SGD 5,500/month	20% of referred client revenue
Partner Enterprise	SGD 12,000/month	30% of referred client revenue

7.4 Unit Economics

All figures in SGD.

Metric	SaaS Enterprise	Private Cloud Pro	Air-Gapped
Annual Contract Value (ACV)	SGD 240,000	SGD 300,000	SGD 380,000
Infrastructure cost (vendor)	~SGD 3,400/month	~SGD 0	~SGD 0
Support cost (fully-loaded)	~SGD 2,000/month	~SGD 2,700/month	~SGD 4,700/month
Gross Margin	~72%	~88%	~85%
Net Revenue Retention (target)	115%	125%	130%

---

8. Go-to-Market Strategy

8.1 Strategic Positioning

DeepGuard is positioned as **"the sovereign AI compliance platform for the post-Mythos era"** — the only tool that applies Mythos-class AI reasoning to your proprietary code and cloud environment, inside your own perimeter, producing audit-ready evidence for every framework that matters.

This positioning:

- Creates existential urgency (the post-Mythos threat is real and immediate)
- Commands premium ACV (CISO and CTO joint buy driven by emergency security spend)
- Differentiates cleanly from AWS Security Hub and all rule-based SAST tools
- Aligns with regulatory deadline convergence (EU AI Act, PCI-DSS v4.0, DORA)
- Opens the multi-cloud and air-gapped market that no competitor can serve

8.2 The Mythos GTM Catalyst — July 2026 Preparation

The publication of the Project Glasswing vulnerability disclosure report in **July 2026** will be the largest single demand catalyst the security tooling market has seen in a decade. DeepGuard's GTM execution must be timed to capitalise on this:

Pre-July 2026 (now through June):

- Publish "The CISO's Guide to Post-Mythos Enterprise Code Scanning" — authoritative positioning content aligned with CSA and IANS guidance already circulating
- Reach out directly to CISOs at top-50 Singapore financial institutions and government agencies with a concise message: *"When the July Glasswing report drops, you will need to show your board that you have scanned your proprietary code. Here is how."*
- Accelerate design partner onboarding — offer 60-day emergency pilots at no cost for organisations that commit to a contract at pilot conclusion
- Brief MAS-accredited assessors and Big 4 auditors on what AI-powered scanning evidence they should be requesting post-Glasswing

July 2026 — Glasswing Response Sprint:

- Launch "Glasswing Readiness Assessment" — a fast-track 2-week scanning engagement targeting the vulnerability classes Glasswing discloses
- Issue press releases positioning DeepGuard as the enterprise answer to Glasswing's scope gap
- Activate partner channels for rapid deal flow
- Target inbound leads from enterprises seeking emergency compliance evidence

August 2026 — EU AI Act Enforcement Convergence:

- EU AI Act Article 9 risk management deadline creates a second wave of urgency within weeks of the Glasswing report
- Offer bundled "Glasswing + EU AI Act" scanning package targeting European and EU-exposed enterprises

8.3 Phase 1: Foundation & Validation (Months 1–6)

Objective: 5 paying design partners; establish proof points for regulated industries in Singapore.

Target Geography: Singapore (initial), expanding to wider SEA.

Why Singapore First:

- MAS TRM creates mandatory compliance obligations for 200+ licensed financial institutions
- Singapore government actively promoting AI governance (PDPC AI governance framework v2, IMDA Model AI Governance)
- Hub for regional HQ of major banks, insurers, and fintechs with the most acute data residency requirements in Asia
- Post-Mythos urgency is particularly acute for financial institutions with decades-old codebases

Actions:

- 90-day pilot with paid contract at completion; case study rights required
- Focus: MAS TRM + OWASP ASVS L2 + AWS infrastructure scanning as initial trio
- Relationships with MAS-accredited assessors and Big 4 audit firms as referral partners
- Apply for Enterprise Development Grant (EDG), MAS FSTI grant
- Thought leadership: "Why Project Glasswing Is Not Enough for Your Enterprise Code"
- Present at ISACA Singapore Chapter, Cloud Security Alliance Singapore events

KPIs: 5 signed design partners; SGD 400K ARR by Month 6; 3 completed audit reports accepted by external auditors; 2 public case studies

8.4 Phase 2: Land & Expand (Months 6–18)

Objective: SGD 3.4M ARR; channel partnerships; multi-cloud scanning; capitalise on July 2026 Glasswing catalyst.

Channel Partnerships:

- Big 4 (Deloitte, PwC, KPMG, EY) — tool + audit credibility; 15% referral
- AWS Marketplace listing (enterprise committed spend); target AWS Security Competency
- Azure Marketplace — Microsoft-centric enterprise buyers
- Regional SIs: NCS, ST Engineering, Ensign InfoSecurity

Product-Led Expansion:

- CI/CD integration (GitHub Actions, GitLab CI, Azure DevOps)
- Slack/Jira/ServiceNow integration
- API-first design for GRC platform integration (ServiceNow, Archer, Vanta, Drata)
- Multi-cloud connector (AWS + Azure) by Month 12

KPIs: SGD 3.4M ARR by Month 18; 3 Big 4 agreements; AWS + Azure Marketplace live; 20+ enterprise customers; Glasswing-response sprint closes 5+ emergency deals

8.5 Phase 3: Geographic Scale & Multi-Cloud Leadership (Months 18–36)

Objective: SGD 11M–16M ARR; US market entry; GCP connector live; category leadership.

US Market Entry:

- Healthcare (HIPAA), financial services (SOC 2, PCI-DSS, FFIEC), AI companies (NIST AI RMF, EU AI Act extraterritorial)
- SOC 2 Type II and ISO 27001 certifications as credibility signals
- FedRAMP authorization initiation (Month 12 parallel track)
- US CISO community outreach via RSA Conference, Black Hat, and Gartner Security Summit

M&A; / Strategic Positioning:

- Acquisition targets: Palo Alto Networks (XSIAM), CrowdStrike (Falcon Platform), Wiz, Snyk, AWS, Microsoft
- Target exit: 10–15x ARR → SGD 110M–240M at SGD 11M–16M ARR

8.6 Sales Motion by Customer Segment

All ACV figures in SGD.

Customer Type	Primary Buyer	Sales Motion	Sales Cycle	ACV (SGD)
SME / Startup (SaaS)	CTO / VP Engineering	Self-serve trial	2–4 weeks	SGD 8K–35K
Mid-market Enterprise	CISO + AppSec Manager	Direct sales, POC	4–8 weeks	SGD 35K–115K
Large Enterprise (Private Cloud)	CISO + Procurement	Enterprise sales + PS	3–6 months	SGD 200K–380K
Multi-Cloud Enterprise	CISO + CTO + Cloud Architects	Technical POC	4–8 months	SGD 300K–470K
Government / Defence	IT Security Director	Tender / RFP	6–12 months	SGD 270K–675K
Post-Mythos Emergency	CISO (board-driven)	Fast-track pilot	2–4 weeks	SGD 115K–200K

Customer Type	Primary Buyer	Sales Motion	Sales Cycle	ACV (SGD)
MSSP / Partner	VP Partnerships	Partner sales	4–8 weeks	SGD 66K–145K/year

9. Financial Projections

9.1 Revenue Build (Conservative Case)

All figures in Singapore Dollars (SGD). Exchange reference rate: SGD 1.35 per USD 1.00.

Year	Enterprise VPC	Enterprise SaaS	MSSP/Partners	Total ARR (SGD)	New Customers	Gross Margin
Year 1	SGD 570K (3 customers)	SGD 243K (6 customers)	SGD 0	**SGD 813K**	9	74%
Year 2	SGD 2.08M (8 customers)	SGD 729K (18 customers)	SGD 243K (3 partners)	**SGD 3.05M**	+21	79%
Year 3	SGD 5.67M (18 customers)	SGD 1.70M (35 customers)	SGD 972K (8 partners)	**SGD 8.34M**	+44	83%
Year 4	SGD 11.34M (35 customers)	SGD 3.24M (60 customers)	SGD 2.03M (14 partners)	**SGD 16.61M**	+67	85%
Year 5	SGD 17.82M (55 customers)	SGD 5.67M (100 customers)	SGD 3.89M (24 partners)	**SGD 27.38M**	+80	87%

Note: Projections do not model the upside from the July 2026 Glasswing demand catalyst, which is expected to compress the Year 1 ramp and accelerate Year 2 substantially above conservative case.

9.2 Cost Structure

All figures in SGD. Salary basis: Singapore 2025/2026 market rates with employer CPF contribution (17%) and standard benefits. Sources: Kaopiz Singapore SWE Salary Benchmarks 2026; NodeFlair Singapore Salary Data 2026; RepVue Singapore AE Compensation 2025.

Singapore Salary Benchmarks Used

Role	Annual Base Salary (SGD)	Total Employment Cost incl. CPF + Benefits
CTO / VP Engineering	SGD 240,000–300,000	SGD 295,000–370,000
Principal / Staff Engineer	SGD 180,000–240,000	SGD 220,000–295,000
Senior Software Engineer	SGD 140,000–180,000	SGD 170,000–220,000
Mid-level Software Engineer	SGD 96,000–130,000	SGD 117,000–157,000
Junior Software Engineer	SGD 60,000–84,000	SGD 73,000–100,000
VP / Head of Sales	SGD 180,000–240,000	SGD 220,000–295,000
Enterprise Account Executive	SGD 100,000–148,000 base + OTE	SGD 145,000–220,000 total cost
Marketing Manager	SGD 84,000–108,000	SGD 100,000–130,000
Customer Success Manager	SGD 72,000–100,000	SGD 87,000–120,000

Annual Cost Build

Cost Category	Headcount	Year 1 (SGD)	Year 2 (SGD)	Year 3 (SGD)
Engineering	4 → 8 → 12 FTE	—	—	—
CTO + 1 Principal Engineer	2 FTE	SGD 590,000	SGD 590,000	SGD 590,000
Senior Engineers	2→4→5 FTE	SGD 380,000	SGD 760,000	SGD 950,000
Mid-level Engineers	0→2→4 FTE	SGD 0	SGD 274,000	SGD 548,000
Junior Engineers	0→0→1 FTE	SGD 0	SGD 0	SGD 87,000
Engineering Subtotal		*SGD 970,000*	*SGD 1,624,000*	*SGD 2,175,000*
Sales & Marketing	1 → 4 → 6 FTE	—	—	—
VP / Head of Sales	0→1→1 FTE	SGD 0	SGD 257,000	SGD 257,000
Enterprise Account Executives	1→2→3 FTE	SGD 185,000	SGD 370,000	SGD 555,000
Marketing Manager	0→1→2 FTE	SGD 0	SGD 115,000	SGD 230,000
Sales & Marketing Subtotal		*SGD 185,000*	*SGD 742,000*	*SGD 1,042,000*
Customer Success	0 → 2 → 3 FTE	—	—	—
Customer Success Managers	0→2→3 FTE	SGD 0	SGD 207,000	SGD 311,000
CS Subtotal		*SGD 0*	*SGD 207,000*	*SGD 311,000*
Infrastructure (AWS SaaS hosting)	—	SGD 65,000	SGD 130,000	SGD 245,000
G&A; + Legal + Compliance	—	SGD 180,000	SGD 240,000	SGD 310,000
Total OpEx		**SGD 1,400,000**	**SGD 2,943,000**	**SGD 4,083,000**

Infrastructure cost is for DeepGuard's own SaaS platform only. Private Cloud and Air-Gapped deployments run on the customer's own infrastructure at zero marginal cost to DeepGuard.

9.3 Funding Requirements

- **Seed Round**: SGD 1.6M — 18 months runway for a 4-person founding team (CTO + 2 Senior Engineers + CEO/BizDev); MVP build; 5 design partners. Apply for MAS FSTI grant (up to SGD 1M) and EDG grant (up to 70% qualifying costs) to extend runway.
- **Series A**: SGD 8M–11M at Month 18 (triggerable at SGD 2M+ ARR) — expand sales team, US market entry, multi-cloud connectors, SOC 2 Type II certification, GPU infrastructure for open-source LLM benchmarking
- **Break-even**: Approximately Month 24 assuming Series A raised at Month 18

10. Risk Assessment

Risk	Likelihood	Impact	Mitigation
LLM hallucination produces incorrect findings	Medium	High	Semgrep/AST/Config validation layer; every finding must reference specific evidence; human review gate; fine-tuned evaluation benchmark
AWS/Azure/GCP build equivalent multi-cloud tools	Low	High	Cloud providers are structurally incentivised to remain cloud-specific; cross-cloud neutrality is DeepGuard's permanent moat
Open-source LLM quality gap in air-gapped mode	Low	Medium	Qwen3-Coder-480B achieves 69.6% SWE-Bench Verified, surpassing GPT-4o; Qwen3-Coder-Next-80B achieves 70%+ at 46GB VRAM — quality gap with proprietary models is now minimal for code tasks
July 2026 Glasswing report delayed or limited scope	Low	Low	Mythos capabilities are already disclosed; enterprise urgency is already established regardless of report timing
Incumbent CSPM (Wiz, Prisma) adds LLM reasoning	Medium	Medium	CSPM vendors lack source code and custom policy; architectural pivot takes 18–24 months; first-mover advantage in AI governance
Liability for missed critical vulnerabilities	Medium	High	Contractual disclaimer: tool assists qualified review, does not replace it; professional indemnity insurance; Checkmarx/Veracode precedent
Cloud provider API changes break connectors	Medium	Low	Abstracted provider interface with automated integration tests; framework maintenance subscription funds connector upkeep
EU AI Act classifies DeepGuard as high-risk AI	Low	Medium	Security scanning tools are likely Annex III exempt; maintain compliance roadmap for the product itself

11. Technical Architecture & The Odysseus Engine

11.1 Architecture Philosophy: Cloud-Agnostic by Design

DeepGuard is built on a **cloud-agnostic core** from inception. The architecture follows three principles:

Abstraction at every infrastructure boundary: All cloud-specific services (storage, compute, secrets, queuing, LLM) are accessed through provider-neutral interfaces with pluggable adapters

Kubernetes-first runtime: The agent execution layer runs on standard Kubernetes, deployable on EKS, AKS, GKE, OpenShift, or bare-metal K8s

Open standards for persistence: PostgreSQL (pgvector) for vector storage and state; S3-compatible object storage (AWS S3, Azure Blob via S3 proxy, GCS via S3 proxy, MinIO for on-prem); standard OIDC for authentication

11.2 System Overview

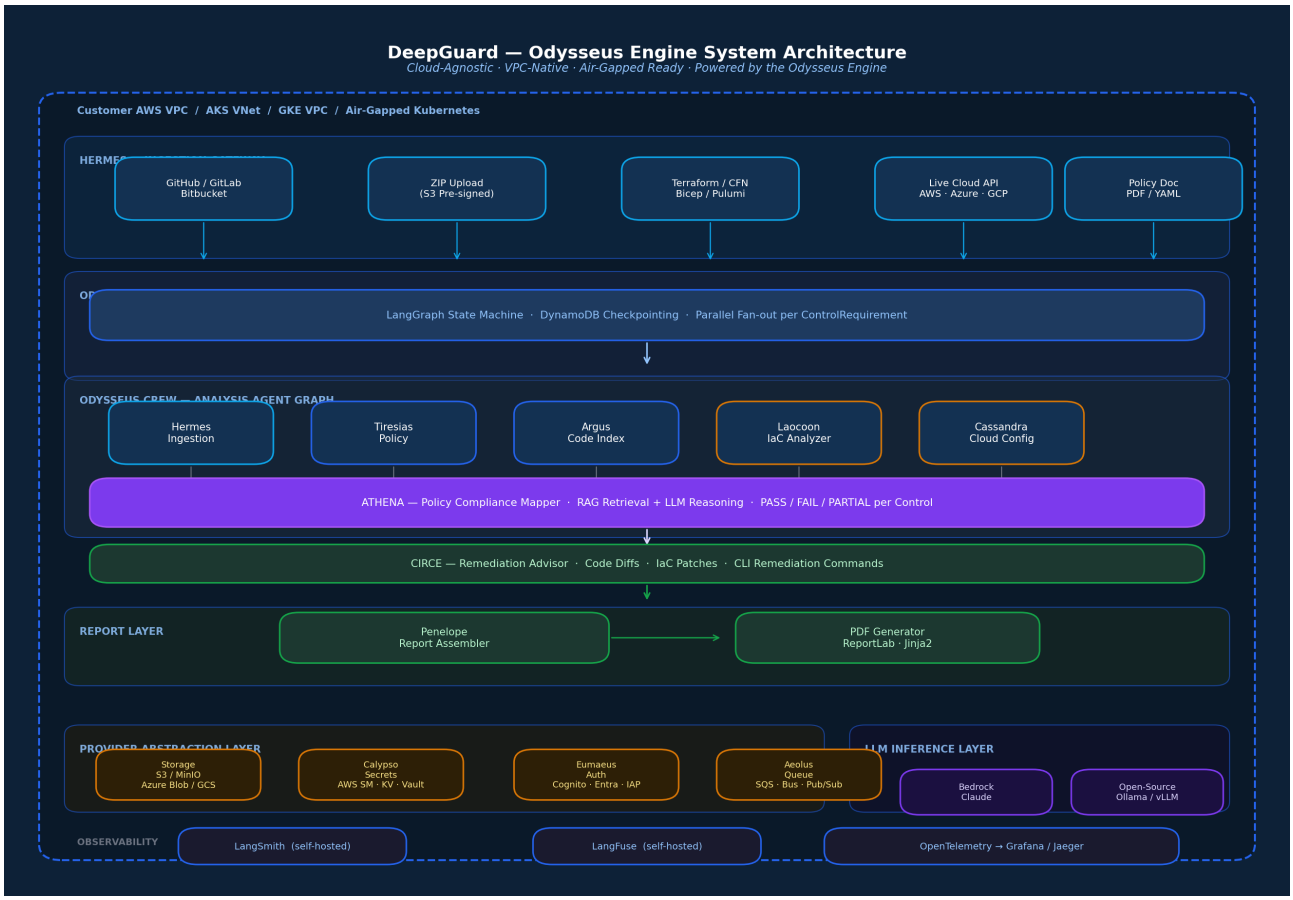

Figure 1: DeepGuard — Odysseus Engine System Architecture · Cloud-Agnostic · VPC-Native

11.3 LangGraph Agent Pipeline — The Odysseus Engine Crew

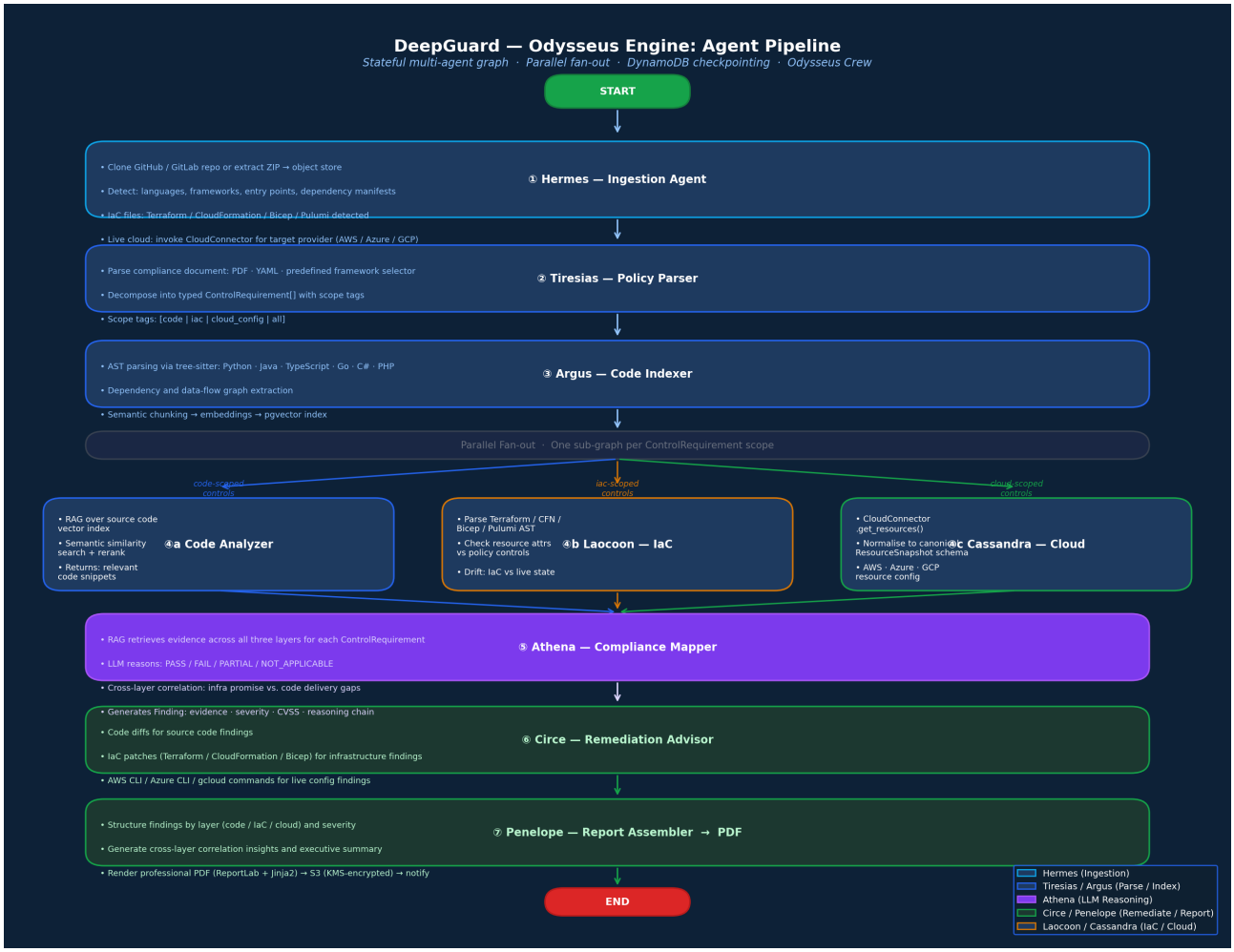

Figure 2: Odysseus Engine Agent Pipeline — Hermes · Tiresias · Argus · Laocoon · Cassandra · Athena · Circe · Penelope

11.4 Technology Stack

Layer	Technology	Cloud-Agnostic Notes
Agent Orchestration	LangGraph 0.2+	Runs on any Kubernetes
LLM Framework	LangChain 0.3+	Supports Bedrock, Azure OpenAI, Vertex AI, Ollama
Development Tracing	LangSmith (self-hosted)	No cloud dependency
Production Observability	LangFuse (self-hosted)	OpenTelemetry export
Code Parsing	tree-sitter, semgrep	Language-native
IaC Parsing	python-hcl2, cfn-flip, azure-mgmt-resource	Provider-specific behind unified interface
Vector Store	pgvector (PostgreSQL)	RDS / Azure DB / Cloud SQL / bare-metal
LLM — AWS	Amazon Bedrock (Claude 3 Sonnet/Opus)	VPC Endpoint; no internet egress
LLM — Azure	Azure OpenAI Service (GPT-4o)	Private Endpoint; no internet egress
LLM — GCP	Google Vertex AI (Gemini Pro)	VPC Service Control
LLM — Air-Gapped	Ollama + open-source model (see Section 12)	Zero external calls

Layer	Technology	Cloud-Agnostic Notes
Object Storage	S3-compatible API	AWS S3 / MinIO / Azure Blob / GCS
Secrets	Provider-pluggable	AWS SM / Azure KV / GCP SM / HashiCorp Vault
Authentication	OIDC-compliant	Cognito / Azure AD / GCP IAP / Keycloak
Job Queue	Provider-pluggable	SQS / Azure Service Bus / GCP Pub/Sub / RabbitMQ
API Layer	FastAPI + Uvicorn	Containerised; cloud-agnostic
Frontend	Next.js 14 + TailwindCSS	Static build; any CDN or K8s
Infrastructure	Terraform modules	Per-provider with shared core
Container Runtime	Kubernetes (Helm charts)	EKS / AKS / GKE / OpenShift / bare-metal
Report Generation	ReportLab + Jinja2	No cloud dependency

11.5 The Odysseus Engine — Module Architecture and Mythological Lineage

Every agent in the DeepGuard pipeline is named after a character from the Homeric cycle whose nature maps precisely to that agent's function. This naming reflects a deliberate design philosophy: each module embodies a specific capability archetype, and the mythology provides a memorable, auditable mental model for the full compliance analysis journey — from ingestion to report delivery.

Mythological Character	Role in Greek Mythology	DeepGuard Module	Functional Correspondence
Odysseus	The hero; navigates every danger through *m■tis* (cunning intelligence); was warned by Tiresias and prepared accordingly; tied himself to the mast as a structural constraint	**Odysseus Engine** — LangGraph Orchestration Core	Orchestrates the entire compliance analysis journey; applies AI reasoning at every node; provides the stateful backbone the crew operates within
Hermes	Messenger of the gods; carries information between worlds; crosses every boundary — between the living and dead, between mortals and Olympus; guide of souls	**Hermes** — Ingestion Gateway & Agent	Moves code repositories, IaC configurations, cloud API data, and policy documents from the external world into the DeepGuard analysis environment
Tiresias	Blind prophet of Thebes; reads the laws of fate past and future; Odysseus descended to the Underworld specifically to consult him on the rules he must follow	**Tiresias** — Policy Parser Agent	Reads and decomposes compliance policies, regulations, and standards — OWASP, ISO 27001, EU AI Act, MAS TRM — into structured, typed control requirements with scope tags
Argus Panoptes	The giant with a hundred eyes who never sleeps; could see in all directions simultaneously; set as guardian precisely because nothing escaped his sight	**Argus** — Code Indexer Agent	Sees every file, function, dependency, and data flow across the entire codebase; builds the all-seeing semantic index that no vulnerability can hide from

Mythological Character	Role in Greek Mythology	DeepGuard Module	Functional Correspondence
Laocoon	Trojan priest who warned *"beware of Greeks bearing gifts"* about the Wooden Horse; he recognised the hidden threat concealed inside a legitimate-looking gift; his warning was ignored — Troy fell	**Laocoon** — IaC Analyzer Agent	Detects the Trojan Horses hidden in infrastructure-as-code: misconfigurations, backdoors, and privilege escalation paths concealed within legitimate-looking Terraform, CloudFormation, and Bicep templates
Cassandra	Prophetess of Troy gifted with perfect foresight by Apollo, then cursed so no one would believe her warnings; she reported the truth — the city burned because it was ignored	**Cassandra** — Cloud Config Agent	Reports truthfully on live cloud misconfigurations; her findings represent real, present dangers — the original Cassandra's warnings, when dismissed, led directly to Troy's destruction
Athena	Goddess of wisdom, craft, and strategic warfare; Odysseus's divine protector throughout his journey; grants reason and judgment over brute strength	**Athena** — Compliance Mapping Agent	Applies LLM reasoning to map evidence to each policy control — PASS / FAIL / PARTIAL / NOT_APPLICABLE — with analytical wisdom rather than pattern-matching rules; performs cross-layer correlation
Circe	The powerful enchantress who transforms men and situations; advises Odysseus on every danger that lies ahead — the Sirens, Scylla, Charybdis — and prescribes the precise response to each	**Circe** — Remediation Advisor Agent	Transforms discovered vulnerabilities into precise remediation actions: code diffs, IaC patches (Terraform /CloudFormation/Bicep), and cloud CLI remediation commands; prescribes the fix, not just the diagnosis
Penelope	Odysseus's faithful and meticulous wife; weaves an intricate tapestry each day with unwavering precision, waiting for the hero's return; her patience and craft produce the final work	**Penelope** — Report Assembler	Weaves the final compliance report from all agent findings: executive summary, per-control evidence, severity heatmap, remediation playbook, and audit appendices — a coherent, audit-ready document
Calypso	The sea-nymph who kept Odysseus safely concealed on her island of Ogygia for seven years; held his secrets beyond the reach of any enemy	**Calypso** — Secrets Management Layer	Keeps credentials, API keys, cloud provider tokens, and LLM API secrets safely hidden within the customer's security perimeter via AWS Secrets Manager / Azure Key Vault / HashiCorp Vault

Mythological Character	Role in Greek Mythology	DeepGuard Module	Functional Correspondence
Aeolus	Keeper of the winds; given authority by Zeus to direct the flows of the air and guide ships on their journeys; controls pace and direction	**Aeolus** — Job Queue & Workflow Orchestration	Controls the flow of analysis tasks across the multi-agent pipeline; manages parallel fan-out per ControlRequirement, convergence back to Athena, and rate limiting of LLM calls
Eumaeus	The faithful swineherd who recognised Odysseus despite his beggar disguise; the loyal gatekeeper who let the true master — and only the true master — back into the estate	**Eumaeus** — Authentication & Identity Layer	Verifies true identity; ensures only authorised principals access the system and its findings via OIDC (Cognito / Azure AD / GCP IAP / Keycloak)

The journey follows Odysseus's own arc: Hermes receives the artefacts at the threshold; Tiresias reads the law in the Underworld of policy documents; Argus sees everything in the codebase simultaneously; Laocoon and Cassandra expose the hidden dangers in infrastructure and live cloud configuration; Athena reasons over the full evidence with divine wisdom; Circe prescribes the precise remedy for each danger; and Penelope weaves it all into the final report — faithful, precise, complete — waiting for Odysseus to return home.

---

12. Open-Source LLM Model Selection

12.1 Why Open-Source LLMs Are Central to DeepGuard

DeepGuard's air-gapped and private deployment modes require LLM inference that runs **entirely within the customer's environment** — no API calls to Anthropic, OpenAI, Google, or any external service. This is not optional for classified environments, defence customers, and regulated financial institutions in strict data sovereignty jurisdictions. Open-source models running on self-managed GPU infrastructure are the only viable path.

The Mythos revelation adds further urgency: organisations now need Mythos-class reasoning depth applied to their own code, but the one model demonstrably capable of that depth (Mythos Preview itself) is withheld from general access. Open-source models that approach frontier capability on code analysis are the practical substitute for air-gapped enterprise deployment.

DeepGuard's model-agnostic architecture allows any GGUF/Ollama-compatible or Hugging Face model to be swapped in at deployment time, and updated independently of the DeepGuard platform. Model selection is a deployment configuration choice, not an architectural constraint.

12.2 Recommended Open-Source Models by Deployment Tier

Tier 1 — Maximum Reasoning Depth (High-Memory GPU Cluster)

DeepSeek-R1 (671B parameters, MoE architecture)

- Best for: Complex cross-file vulnerability reasoning, multi-step compliance chain analysis, deep semantic understanding of authentication and cryptographic flows
- Code benchmark: State-of-the-art on SWE-bench, AIME, and MATH — the strongest open reasoning model available

- Architecture: 671B total parameters, 37B active per forward pass (Mixture of Experts); comparable to frontier proprietary models
- Hardware requirement: 4× NVIDIA A100 80GB or equivalent (H100, A10G)
- Deployment: Ollama `deepseek-r1:671b` or vLLM on Kubernetes GPU nodes
- Licence: MIT — commercially unrestricted
- Key strength in DeepGuard context: Multi-step chain-of-thought reasoning over large codebases; can reason across 128K context to correlate vulnerabilities spanning multiple files and modules
- *(Source: DeepSeek technical report; SiliconFlow open-source LLM cybersecurity benchmark 2026)*

Qwen3-Coder-480B-A35B (480B parameters, MoE architecture) — February 2026

- Best for: Maximum agentic coding depth — the strongest open-source code model available; recommended for critical enterprise environments where scan accuracy is paramount
- Architecture: 480B total parameters, 35B active per forward pass (160 experts, top-8 routing); state-of-the-art MoE efficiency
- Context window: 256K tokens natively; extendable to 1M tokens via extrapolation — can ingest entire large enterprise repositories in a single pass
- Benchmarks: 69.6% on SWE-Bench Verified using SWE-Agent scaffold — surpassing GPT-4o and Claude 3.7 Sonnet on real-world repository-level code tasks
- Hardware requirement: 250GB unified memory minimum (4× H100 80GB or equivalent)
- Deployment: vLLM or SGLang on Kubernetes GPU nodes; quantised GGUF via Ollama for reduced VRAM (Q4: ~140GB)
- Licence: Apache 2.0 — commercially unrestricted
- Key strength in DeepGuard context: Designed specifically for long-horizon agentic coding tasks — exactly the multi-step, multi-file compliance reasoning DeepGuard requires; outperforms all prior open models on real-world code modification benchmarks
- *(Source: Qwen3-Coder-480B Hugging Face model card; apxml.com specifications; NVIDIA NIM model card)*

Qwen3-Coder-Next-80B-A3B (80B parameters, MoE architecture) — February 2026

- Best for: High-performance code analysis on accessible hardware; the recommended default for most private cloud deployments at this tier
- Architecture: 80B total parameters, only 3B active per forward pass — delivers performance comparable to 10–20× larger dense models
- Context window: 256K tokens
- Benchmarks: Over 70% on SWE-Bench Verified; competitive with Qwen3-Coder-480B at a fraction of the compute cost; excels at long-horizon reasoning, complex tool usage, and recovery from execution failures
- Hardware requirement: 46GB RAM/VRAM (85GB for 8-bit); fits on a single H100 80GB with quantisation
- Deployment: Ollama `qwen3-coder-next:80b` or vLLM; GGUF quantised variants available via Unsloth
- Licence: Apache 2.0 — commercially unrestricted
- Key strength in DeepGuard context: Exceptional cost-to-performance ratio; the extreme MoE efficiency makes it practical for continuous CI/CD scanning without prohibitive GPU costs
- *(Source: Qwen3-Coder-Next technical report arXiv:2603.00729; Unsloth documentation; DEV Community 2026 deployment guide)*

Tier 2 — Optimised Code Analysis (Standard GPU Node)

Qwen3-Coder-Plus (32B dense) — 2026

- Best for: Highest-quality single-GPU code analysis with the Qwen3 generation improvements; the recommended default for standard private cloud deployments
- Upgrade from Qwen2.5-Coder-32B with significantly improved agentic capabilities and instruction following

- Context window: 128K tokens
- Hardware requirement: 1× A100 80GB or 2× A10G 24GB
- Deployment: Ollama `qwen3-coder-plus` or vLLM
- Licence: Apache 2.0
- Key strength: Balances reasoning depth and hardware accessibility; the most deployable option for organisations with a single A100 node
- *(Source: SiliconFlow Qwen3 guide 2026; Qwen3 Coder Plus API pricing data)*

Qwen 3.6 Plus Preview (1M context) — 2026

- Best for: Full-repository analysis of large enterprise monoliths where chunking introduces reasoning fragmentation
- Context window: 1,000,000 tokens — the largest available context among open-weight models; can process an entire medium-sized enterprise codebase in one inference call
- Optimised for text-heavy workloads: large codebase analysis, long-document policy reasoning, and complex multi-step agents
- Hardware requirement: Multi-GPU cluster; typically 8× A100 80GB for full precision
- Key strength: Eliminates RAG retrieval errors for large codebases — the entire context is available to the model simultaneously, producing more coherent cross-file vulnerability reasoning than chunked approaches
- *(Source: BuildFastWithAI Qwen 3.6 Plus review 2026)*

DeepSeek Coder V2 (16B / 236B variants)

- Best for: Specialist code understanding across 300+ programming languages; ideal for polyglot enterprise codebases
- Significantly outperforms CodeLlama-34B across all code benchmarks (HumanEval, MBPP, DS-1000)
- 16B variant fits on a single A10G 24GB; 236B variant requires 4× A100 equivalent
- Hardware requirement: 1× A10G 24GB (16B); 4× A100 80GB (236B)
- Deployment: Ollama `deepseek-coder-v2:16b` or `deepseek-coder-v2:236b`
- Licence: DeepSeek Coder Licence (permissive for most commercial use)
- Key strength: Widest language coverage; strong at dependency graph analysis and cross-language vulnerability detection
- *(Source: DeepSeek Coder technical report; Medium benchmark study 2025)*

DeepSeek Coder V2 (16B / 236B variants)

- Best for: Specialist code understanding across 300+ programming languages; ideal for polyglot enterprise codebases
- Significantly outperforms CodeLlama-34B across all code benchmarks (HumanEval, MBPP, DS-1000)
- 16B variant fits on a single A10G 24GB; 236B variant requires 4× A100 equivalent
- Hardware requirement: 1× A10G 24GB (16B); 4× A100 80GB (236B)
- Deployment: Ollama `deepseek-coder-v2:16b` or `deepseek-coder-v2:236b`
- Licence: DeepSeek Coder License (permissive for most commercial use)
- Key strength: Widest language coverage; strong at dependency graph analysis and cross-language vulnerability detection
- *(Source: DeepSeek Coder technical report; Medium benchmark study 2025)*

Tier 3 — Efficient Deployment (Moderate GPU or CPU-Only)

Llama 3.3 70B (Meta)

- Best for: Balanced reasoning and code analysis on accessible hardware; the recommended model for organisations deploying on existing GPU infrastructure without dedicated A100s

- Strong performance on code understanding despite not being a code-specific model
- Hardware requirement: 2× A10G 24GB or 4× consumer RTX 4090
- Deployment: Ollama `llama3.3:70b`
- Licence: Meta Llama 3.3 Community Licence (commercially usable)
- Key strength: Well-understood, widely deployed, strong community support; excellent choice for organisations prioritising operational reliability over raw benchmark scores

GLM-4.5 (Zhipu AI)

- Best for: Large-context analysis requiring entire codebase ingestion in a single pass
- 131K context length — can process large monolithic codebases without chunking
- Exceptional at generating detailed, structured security reports in a single inference call
- Hardware requirement: 2× A100 80GB
- Deployment: Ollama or custom vLLM deployment
- Licence: Commercial use permitted
- Key strength: The 131K context enables full-repository analysis patterns that smaller-context models must approximate with RAG chunking; produces more coherent cross-file reasoning
- *(Source: GLM-4.5 technical report; SiliconFlow cybersecurity benchmark 2026)*

Mistral Small 3.1 / Mixtral 8x7B

- Best for: Resource-constrained deployments; organisations with legacy GPU infrastructure
- Mixtral 8x7B: MoE architecture with 12.9B active parameters; runs on 2× RTX 4090 or equivalent
- Acceptable code analysis quality for simpler compliance frameworks (OWASP Top 10, CIS Benchmarks)
- Hardware requirement: 2× RTX 4090 (Mixtral 8x7B); 1× A10G (Mistral Small 3.1)
- Deployment: Ollama `mixtral:8x7b` or `mistral-small:3.1`
- Licence: Apache 2.0
- Key strength: Lowest hardware floor for air-gapped deployment; accessible to organisations without enterprise GPU infrastructure

StarCoder2 (15B, BigCode)

- Best for: Fast, lightweight code-specific analysis where latency matters more than depth
- Trained specifically on code; strong at code completion and structural analysis
- Hardware requirement: 1× A10G 24GB or 2× RTX 4090
- Deployment: Ollama `starcoder2:15b`
- Licence: BigCode OpenRAIL-M — commercially usable
- Key strength: Fastest inference per token among code-specialist models; suitable for CI/CD pipeline integration where scan time is a constraint

12.3 Model Selection Guide by Deployment Mode

Deployment Mode	Recommended Model	Rationale
SaaS (cloud-hosted)	Amazon Bedrock Claude Opus 4 / Sonnet 4	Frontier capability; managed; no GPU ops burden
AWS Private Cloud	Bedrock Claude (VPC Endpoint) or Qwen3-Coder-Next-80B	Bedrock preferred; open-source fallback for strict data controls
Azure Private Cloud	Azure OpenAI GPT-4o (Private Endpoint)	Microsoft-managed; Private Endpoint ensures no egress
GCP Private Cloud	Vertex AI Gemini Pro (Private Service Connect)	Google-managed; VPC-native

Deployment Mode	Recommended Model	Rationale
Air-Gapped Standard	Qwen3-Coder-Next-80B-A3B	70%+ SWE-Bench Verified; 46GB VRAM; Apache 2.0
Air-Gapped Max Accuracy	Qwen3-Coder-480B-A35B	69.6% SWE-Bench; best open-source code agent; 250GB RAM
Air-Gapped Max Context	Qwen 3.6 Plus (1M context)	Full-repo ingestion; eliminates RAG fragmentation
Air-Gapped Polyglot Enterprise	DeepSeek-R1 671B + Coder V2 236B	Deep reasoning + 300+ language coverage
Air-Gapped Resource-Constrained	Llama 3.3 70B or Mixtral 8x7B	Runs on existing GPU infrastructure; no new hardware
CI/CD Pipeline (fast scan)	Qwen3-Coder-Next-80B-A3B (Q4) or StarCoder2 15B	Sub-60s scan times; pre-commit check quality

12.4 Model Evaluation & Benchmarking

DeepGuard maintains a continuously updated **compliance-specific benchmark suite** (via LangSmith) that evaluates each supported model on:

- **Vulnerability detection accuracy**: Known-positive and known-negative test cases across OWASP Top 10, ASVS, and CIS benchmarks, scored against ground-truth findings
- **Policy-mapping precision**: Whether LLM reasoning correctly maps code evidence to the specific policy control being evaluated
- **False positive rate**: Critical metric — excessive false positives destroy analyst trust; tracked per model per framework
- **Remediation correctness**: Whether generated code diffs and IaC patches are syntactically valid and semantically correct
- **Context utilisation**: How effectively the model uses the full retrieved context vs. hallucinating from training data

Benchmark results are provided to customers as part of the deployment documentation, enabling informed model selection based on their specific compliance framework priorities.

---

13. AWS Infrastructure & Configuration Scanning

13.1 Overview

Beyond source code and IaC analysis, DeepGuard includes a dedicated **AWS Cloud Configuration Agent** that connects to a customer's live AWS environment via read-only IAM role and scans running resource configurations against compliance requirements.

This closes the critical gap between what is declared in IaC and what is actually running in production — a discrepancy that causes significant compliance failures in real audits (e.g., a Terraform module deploys encryption, but a manually created resource does not). In the post-Mythos era, this gap is even more critical: live cloud misconfigurations are a primary attack surface that AI-powered adversaries will target.

13.2 AWS Resource Coverage

Identity & Access Management

- IAM users, roles, policies (inline and managed) — least privilege analysis, wildcard permissions, privilege escalation paths
- IAM password policy — complexity, rotation, MFA enforcement
- Service control policies (SCPs) — organisation-level guardrails
- Permission boundaries and AWS SSO / IAM Identity Center configurations

Network Security

- VPC topology — subnet segregation, flow logs, default VPC usage
- Security groups — overly permissive inbound/outbound rules (0.0.0.0/0 exposure)
- Network ACLs, VPC peering and Transit Gateway configurations
- PrivateLink endpoints and Route 53 DNS configuration

Storage & Data

- S3 buckets — public access block, ACLs, bucket policies, CORS, versioning, MFA delete, encryption (SSE-S3 vs SSE-KMS)
- RDS instances — encryption, public accessibility, backup retention, Multi-AZ
- DynamoDB, Secrets Manager, Parameter Store, EBS volumes, EFS

Compute & Containers

- EC2 instances — IMDSv2 enforcement, public IP, security groups, outdated AMIs
- ECS task definitions — privileged containers, secrets in environment variables
- EKS clusters — API server access, envelope encryption, RBAC, node IMDSv2
- Lambda functions — function policies, environment variable secrets, VPC placement
- Auto Scaling Groups — launch template configuration

Security Services Configuration

- CloudTrail — multi-region, log file validation, CloudWatch integration
- AWS Config — rules enabled, configuration recorder, delivery channel
- GuardDuty — enabled across all regions, findings export
- Security Hub, Macie, Inspector, WAF, Shield Advanced coverage

Encryption & Key Management

- KMS keys — rotation, key policies, cross-account usage
- ACM certificates — expiry monitoring, domain validation type

Logging & Monitoring

- CloudWatch Log Groups — retention, encryption, metric filters
- VPC Flow Logs, S3 access logging, ALB/NLB access logging

13.3 AWS Compliance Mapping Examples

Policy Requirement	AWS Resource Scanned	Compliance Check
PCI-DSS 2.2.1 — Secure configurations	EC2, RDS, EKS	IMDSv2, no default VPC, no public RDS
PCI-DSS 7.2 — Least privilege access	IAM roles and policies	No wildcard actions on sensitive resources
PCI-DSS 10.3 — Audit log protection	CloudTrail, S3 log bucket	Log file validation, bucket policy restricts delete

Policy Requirement	AWS Resource Scanned	Compliance Check
NIST 800-53 AC-2 — Account management	IAM, IAM Identity Center	MFA enforced, inactive accounts reviewed
MAS TRM 9.1 — Access control	IAM, SCP, Security Groups	Least privilege, network segmentation
ISO 27001 A.12.4 — Event logging	CloudTrail, Config, GuardDuty	Logging enabled and retained per policy
CIS AWS Foundations 1.x	IAM password policy	Complexity, expiry, MFA on root
OWASP LLM Top 10 (LLM09)	Bedrock model access policies	Invocation access scoped to authorised principals
EU AI Act Art. 9 — Risk management	S3, IAM, CloudTrail for AI workloads	AI system audit trail integrity and access controls

13.4 Cross-Layer Correlation — The Unique Insight

DeepGuard's most powerful capability is **cross-layer correlation** — finding the gaps between infrastructure promises and application code delivery:

- S3 server-side encryption enabled (infra PASS) → Application code logs decrypted values (code FAIL) → **Encryption bypass via application layer**
- Security group blocks port 5432 (network PASS) → Application connection string contains no SSL enforcement (code FAIL) → **Encryption in transit not enforced at application layer**
- IAM role has least-privilege policy (IAM PASS) → Lambda function assumes a broader role at runtime (code FAIL) → **Privilege escalation via runtime role assumption**
- GuardDuty enabled (config PASS) → Application catches and suppresses all exceptions without logging (code FAIL) → **Threat detection blinded by application-layer log suppression**

---

14. Cloud-Agnostic Design & Multi-Cloud Roadmap

14.1 Provider Abstraction Architecture

All cloud-specific integrations are encapsulated behind a `CloudProvider` interface exposing a uniform API regardless of underlying provider. New providers are added by implementing this interface — agents and compliance reasoning never interact with provider-specific SDKs directly.

All resource data is normalised to a **canonical ResourceSnapshot schema** (cloud-neutral JSON) before entering the compliance reasoning pipeline. Compliance frameworks are written once, applied everywhere. A new cloud provider requires only a new adapter — zero changes to agent logic.

14.2 Infrastructure Deployment: Terraform Module Library

```
deepguard-terraform/
■■■ modules/
■ ■■■ core/ Cloud-agnostic: K8s manifests, Helm, DB schema
■ ■■■ aws/ EKS, RDS, S3, Bedrock, Cognito
■ ■■■ azure/ AKS, Azure DB, Blob, Azure OpenAI, Entra ID
■ ■■■ gcp/ GKE, Cloud SQL, GCS, Vertex AI, Cloud IAP
■ ■■■ onprem/ Bare-metal K8s, MinIO, Vault, Keycloak, Ollama
■■■ examples/
■■■ aws-single-account/
■■■ aws-multi-account/
■■■ azure-enterprise/
```

```
■■■ gcp-enterprise/
■■■ multi-cloud-hub/
■■■ airgapped-datacenter/
```

14.3 Phase 4 — Azure Private Cloud (Months 24–30)

Azure Resource Scanning Coverage:

- Azure Active Directory / Entra ID: Conditional access, MFA, PIM, guest user access, service principal credential expiry
- Azure RBAC: Role assignments, Owner/Contributor over-assignment, scope analysis
- Virtual Networks: NSG rules, Azure Firewall, Private Endpoints, peering topology
- Storage Accounts: Public access, HTTPS enforcement, SAS policies, soft delete, CMK
- Azure SQL / Cosmos DB: TDE, Advanced Threat Protection, auditing, private endpoint
- AKS Clusters: API server authorised IPs, RBAC, Azure AD integration, network policy
- Key Vault: Soft delete, purge protection, private endpoint, certificate expiry
- App Service / Function Apps: HTTPS-only, managed identity, TLS version
- Microsoft Defender for Cloud: Coverage score, recommendation status

Deployment: Terraform `azure` module on AKS; LLM via Azure OpenAI Private Endpoint; secrets in Azure Key Vault; auth via Azure AD OIDC

14.4 Phase 5 — Google Cloud Platform (Months 30–36)

GCP Resource Scanning Coverage:

- Cloud IAM: Policy bindings (primitive roles), service accounts (unused, key rotation), Workload Identity
- VPC Networks: Firewall rules (0.0.0.0/0 ingress), VPC Service Controls, Shared VPC
- Cloud Storage: Uniform bucket-level access, public access prevention, CMEK
- Cloud SQL: SSL enforcement, authorised networks, backup, binary logging
- GKE Clusters: Workload Identity, Binary Authorization, Shielded nodes, network policy
- Logging: Audit logs enabled, log sinks configured, retention

Deployment: Terraform `gcp` module on GKE Autopilot; LLM via Vertex AI Gemini Pro (Private Service Connect); secrets in GCP Secret Manager

14.5 Phase 6 — Air-Gapped Private Data Centre (Months 36–42)

Target environments: Defence and intelligence agencies; classified government systems; sovereign cloud environments; financial institutions prohibiting any external cloud connectivity; critical national infrastructure operators

Architecture:

- Kubernetes: Red Hat OpenShift, Rancher, or vanilla K8s on customer hardware
- LLM: Ollama with DeepSeek-R1 671B or Qwen2.5-Coder-32B on GPU nodes — 100% on-premises
- Storage: MinIO (open-source, S3-compatible) — customer-managed
- Secrets: HashiCorp Vault (open-source) — customer-managed
- Auth: Keycloak (open-source OIDC) — customer-managed
- Updates: Signed, air-gapped package bundles (Docker tarballs + Helm archives)
- HSM integration for key management in classified environments

- Certifications: FIPS 140-2/3 cryptographic modules; Common Criteria EAL2+ target; FedRAMP High authorization package

Cloud provider scanning in air-gapped mode:

- AWS GovCloud / Secret Region: boto3 with private VPC endpoint
- Azure Government: Azure SDK with sovereign cloud endpoints
- VMware vSphere / Nutanix: Custom `OnPremProvider` adapter using vSphere / Prism API
- OpenStack: Provider adapter for Identity, Compute, Network, Object Storage APIs

14.6 Multi-Cloud Unified Compliance Dashboard (Phase 7+)

- **Unified compliance score** across AWS + Azure + GCP + on-prem in a single metric
- **Cross-cloud risk heatmap** showing which provider and control domain has worst posture
- **Asset inventory correlation**: track the same logical system across providers in a single finding
- **Drift detection**: alert when live cloud configuration diverges from IaC declaration
- **Trend dashboard**: compliance score over time across all providers

---

15. Supported Compliance Frameworks

15.1 Application Security Frameworks

Framework	Version	Scope
OWASP Top 10	2021	Web application vulnerabilities (code)
OWASP ASVS	L1 / L2 / L3	Application security verification (code)
OWASP LLM Top 10	2025	LLM-integrated application security (code + config)
OWASP API Security Top 10	2023	API vulnerability categories (code + IaC)

15.2 Cloud Infrastructure Frameworks

Framework	Version	Scope
CIS AWS Foundations Benchmark	v3.0	AWS live configuration
CIS Azure Foundations Benchmark	v2.0	Azure live configuration
CIS GCP Foundations Benchmark	v2.0	GCP live configuration
CIS Kubernetes Benchmark	v1.8	K8s cluster configuration
AWS Well-Architected Security Pillar	2024	AWS architecture review
NIST SP 800-190	—	Container security

15.3 Industry & Regulatory Frameworks

Framework	Applicability
PCI-DSS v4.0	Payment card processing (code + infra)
HIPAA Security Rule	US healthcare applications handling PHI

Framework	Applicability
SOC 2 Type II (CC series)	SaaS and cloud service providers
MAS TRM	Singapore financial institutions
DORA	EU financial entities
FFIEC IT Examination Handbook	US financial institutions
UK NCSC Cyber Essentials Plus	UK government and suppliers

15.4 International Standards

Standard	Applicability
ISO/IEC 27001:2022 Annex A	International information security management
ISO/IEC 27002:2022	Information security controls guidance
ISO/IEC 27017:2015	Cloud service security controls
ISO/IEC 27018:2019	Cloud PII protection
ISO/IEC 42001:2023	AI management systems
NIST SP 800-53 Rev 5	US federal systems and contractors
NIST SP 800-218 (SSDF)	Secure software development framework
NIST CSF 2.0	Cybersecurity framework
NIST AI RMF 1.0	AI risk management framework

15.5 AI Governance Frameworks

Framework	Applicability
EU AI Act (Regulation EU 2024/1689)	High-risk AI systems in the EU — Articles 9, 10, 12, 15
ISO/IEC 42001:2023	AI management system standard — policy, objectives, and controls
OWASP LLM Top 10 (2025)	Prompt injection, insecure output handling, training data poisoning, model DoS, supply chain vulnerabilities
NIST AI RMF 1.0	Govern, Map, Measure, Manage functions for AI risk
NIST AI RMF Playbook	Implementation guidance for AI RMF functions
Singapore PDPC AI Governance Framework v2	Accountability-based AI governance for Singapore organisations
Google SAIF	Secure AI framework — model training, deployment, inference security

15.6 Custom Policy Support

Organisations may upload proprietary security policies in PDF, YAML, or structured JSON format. DeepGuard's PolicyParserAgent decomposes the document into atomic, verifiable control requirements tagged by scope (code / IaC / cloud config / all) and maps them to the unified analysis pipeline.

16. Report Output Structure

Each DeepGuard compliance report contains:

Cover Page — Customer name, repository/account, framework(s), scan date, report classification, LLM model used

Executive Summary — Unified compliance score per layer (code/IaC/cloud config); risk posture rating; top 5 critical findings; Mythos-era vulnerability surface assessment; immediate actions required

Compliance Posture Dashboard — Visual heatmap across all control domains and all scanning layers

Cross-Layer Correlation Insights — Findings where code and infrastructure gaps interact to compound risk

Findings Register — Complete table: control reference, title, severity, status, affected asset (file:line or resource ARN/ID), CVSS score

Detailed Findings — Per finding: policy text, evidence (annotated code or resource config), LLM reasoning chain, severity justification

Remediation Playbook — Prioritised: code diffs, IaC patches, CLI commands, estimated effort, remediation owner

Infrastructure Configuration Summary — Per-cloud provider: resource inventory, coverage by type, posture score

Methodology & Limitations — Analysis methodology, tool versions, LLM model and version, confidence indicators, known limitations

Appendix A: Policy-to-Control Mapping — Framework requirement → finding → evidence → remediation traceability matrix

Appendix B: Scan Configuration — Repository commit hash, cloud account IDs, framework versions, scan parameters

Appendix C: Asset Inventory — Complete list of all scanned cloud resources by provider and type

---

17. Build Roadmap

Phase 1 — MVP: Code + AWS Infra (Weeks 1–8)

- GitHub and GitLab ingestion + ZIP upload; Python and TypeScript
- OWASP Top 10, OWASP ASVS L1/L2
- AWS infrastructure scanning: IAM, S3, EC2, RDS, CloudTrail, Security Groups, VPC
- Cross-layer correlation (code + AWS config) in a single report
- PDF report with findings, evidence, cross-layer insights
- Terraform AWS deployment template (single-tenant VPC)
- Open-source LLM support: Qwen2.5-Coder-32B via Ollama (air-gapped option from day one)
- LangFuse self-hosted observability; SaaS mode multi-tenant

Phase 2 — Full Code + Full AWS (Weeks 8–20)

- Multi-language AST: Java, Go, C#, PHP
- Full AWS resource coverage (all services in Section 13.2)
- ISO 42001, EU AI Act, OWASP LLM Top 10, NIST AI RMF
- IaC scanning: Terraform, CloudFormation, AWS CDK
- Custom policy ingestion: PDF and YAML

- CI/CD SDK: GitHub Actions, GitLab CI
- LangSmith evaluation suite with compliance-specific benchmarks for all supported models
- SAML/OIDC SSO; AWS Marketplace listing
- DeepSeek-R1 and DeepSeek Coder V2 Ollama support for air-gapped

Phase 3 — Enterprise Hardening (Weeks 20–36)

- Air-gapped Ollama mode (full open-source stack)
- Multi-region SaaS (ap-southeast-1, eu-west-1, us-east-1)
- RBAC with approval workflows; remediation PR auto-generation
- Audit evidence package export (SOC 2, ISO 27001 bundle)
- SOC 2 Type II certification of SaaS platform
- Drift detection for live AWS vs. Terraform state
- Glasswing vulnerability class detection module (post-July 2026 update)

Phase 4 — Azure Private Cloud (Months 24–30)

- Azure cloud configuration scanning (Section 14.3)
- IaC: Azure Bicep and ARM templates
- AKS deployment via Terraform `azure` module
- Azure OpenAI Private Endpoint LLM integration
- Azure Marketplace listing; CIS Azure, UK NCSC frameworks
- Multi-cloud report: unified AWS + Azure posture

Phase 5 — Google Cloud Platform (Months 30–36)

- GCP cloud configuration scanning (Section 14.4)
- GKE deployment via Terraform `gcp` module
- Vertex AI Gemini Pro (Private Service Connect)
- GCP Marketplace listing; CIS GCP Foundations
- Tri-cloud unified report: AWS + Azure + GCP

Phase 6 — Air-Gapped Private Data Centre (Months 36–42)

- Ollama self-hosted LLM on bare-metal GPU (DeepSeek-R1 or Qwen2.5-Coder)
- MinIO + HashiCorp Vault + Keycloak full open-source stack
- OpenShift, Rancher, vanilla K8s deployment
- vSphere and OpenStack provider adapters
- Air-gapped package update mechanism
- FIPS 140-2/3 compliance; HSM integration; Common Criteria EAL2+

Phase 7 — Platform Intelligence (Year 3+)

- Multi-cloud unified compliance dashboard and trend analytics
- Fine-tuned compliance reasoning model on anonymised finding datasets
- GRC platform integrations (ServiceNow, Archer, Vanta, Drata)
- Compliance-as-code IDE SDK
- Automated annual audit evidence collection
- Continuous AI model upgrade path as open-source models close the gap with Mythos-class capability

18. Conclusion & Investment Thesis

The Case in One Paragraph

The Mythos announcement of April 2026 has permanently changed the enterprise security landscape. Every organisation must now assume their proprietary code contains critical, AI-discoverable vulnerabilities that decades of traditional scanning never found. Project Glasswing will patch the open-source foundations — but not your code, not your cloud configuration, not your custom business logic. Anthropic named their model Mythos — after the primordial Greek tales in which hidden truths are finally revealed. DeepGuard responds with the Odysseus Engine: the compliance intelligence platform that was warned, that listened, and that navigates every danger through AI reasoning (*m■tis*), operating invisibly within the customer's own perimeter. DeepGuard is the only platform that applies Mythos-class AI reasoning to proprietary enterprise codebases and cloud environments, privately within the customer's own walls, across all cloud providers, with open-source LLM support for fully air-gapped operation, producing the audit-grade compliance evidence that regulators and boards are now demanding. The market is large, the timing is urgent, the regulatory tailwinds are mandatory, and the competitive moat is structural.

Why DeepGuard Will Win

The convergence of five mutually reinforcing forces creates a uniquely timed and durable opportunity:

Mythos has permanently changed the threat model: Rule-based SAST is now demonstrably inadequate. LLM-powered reasoning is now a requirement, not a differentiator. DeepGuard already delivers it.

Multi-cloud is the default architecture: 87% of enterprises run multi-cloud. No native cloud tool covers the full estate. DeepGuard does.

Regulatory mandates are creating non-discretionary spend: EU AI Act, PCI-DSS v4.0, DORA, MAS TRM, NIST AI RMF — all current, all enforced, all requiring demonstrable evidence that DeepGuard produces.

Data sovereignty locks out external AI tools: Every enterprise with strict data handling requirements cannot use cloud-hosted AI APIs to scan their code. VPC-native and air-gapped deployment is DeepGuard's permanent structural moat.

Open-source LLMs close the access gap: Qwen3-Coder-480B (69.6% SWE-Bench Verified), Qwen3-Coder-Next-80B (70%+, 46GB VRAM), and Qwen 3.6 Plus (1M context) bring Mythos-adjacent reasoning capability to fully air-gapped environments. No competitor has built this integration.

The Investment Case

All SGD figures. Exchange reference rate: SGD 1.35 per USD 1.00.

Metric	Value
Total Addressable Market	~USD 80B (2024) → ~USD 240B (2030), accelerating post-Mythos
Serviceable Addressable Market	~USD 8–10B
Year 5 ARR Target	SGD 27M (conservative)
Year 5 Exit Valuation	SGD 270M–400M at 10–15x ARR

Metric	Value
Key Strategic Acquirers	Palo Alto Networks, CrowdStrike, Wiz, Snyk, AWS, Microsoft
Seed Requirement	SGD 1.6M
Series A Trigger	SGD 2M ARR (~Month 18)
Gross Margin at Scale	85–87%
Payback Period (Enterprise)	8–12 months
Singapore Grants Available	MAS FSTI up to SGD 1M; EDG up to 70% qualifying costs

The window is open now. The frameworks are live, the Mythos threat is real, the regulatory deadlines are set, the multi-cloud reality is entrenched, and the enterprise market is actively seeking a solution that does not yet exist at quality. DeepGuard is that solution.

Document Classification: Confidential — Business Case v5.0

For distribution to investors, strategic partners, and design partners under NDA

---

19. References

Anthropic. (2026, April). *Claude Mythos Preview*. https://red.anthropic.com/2026/mythos-preview/

Anthropic. (2026, April). *Project Glasswing: Securing critical software for the AI era*. https://www.anthropic.com/glasswing

Fortune. (2026, March 26). *Exclusive: Anthropic 'Mythos' AI model representing 'step change' in power revealed in data leak*. https://fortune.com/2026/03/26/anthropic-says-testing-mythos-powerful-new-ai-model-after-data-leak-reveals-its-existence-step-change-in-capabilities/

Fortune. (2026, April 14). *Anthropic's Mythos finds software flaws faster than companies can fix them*. https://fortune.com/2026/04/14/anthropic-mythos-reveals-security-gap-ai-finds-flaws-far-faster-than-companies-can-patch-them/

Axios. (2026, April 7). *Anthropic withholds Mythos Preview model because its hacking is too powerful*. https://www.axios.com/2026/04/07/anthropic-mythos-preview-cybersecurity-risks

CNBC. (2026, April 14). *Jamie Dimon says Anthropic's Mythos reveals 'a lot more vulnerabilities' for cyberattacks*. https://www.cnbc.com/2026/04/14/jamie-dimon-anthropic-mythos-vulnerabilities-cyber-attacks

Council on Foreign Relations. (2026). *Six Reasons Claude Mythos Is an Inflection Point for AI—and Global Security*. https://www.cfr.org/articles/six-reasons-claude-mythos-is-an-inflection-point-for-ai-and-global-security

UK AI Safety Institute. (2026). *Our evaluation of Claude Mythos Preview's cyber capabilities*. https://www.aisi.gov.uk/blog/our-evaluation-of-claude-mythos-previews-cyber-capabilities

IANS Research. (2026, April 13). *Anthropic's 'Project Glasswing' Exposes the Next Challenge for Vulnerability Management*. https://www.iansresearch.com/resources/all-blogs/post/security-blog/2026/04/13/anthropic's--project-glasswing--exposes-the-next-challenge-for-vulnerability-management

Cloud Security Alliance. (2026). *The 'AI Vulnerability Storm': A CISO's Playbook for the Mythos Era*. https://labs.cloudsecurityalliance.org/mythos-ciso/

DarkReading. (2026). *Report: CISOs Should Prepare for Post-Mythos Exploit Storm*. https://www.darkreading.com/cloud-security/csa-cisos-prepare-post-mythos-exploit-storm

VentureBeat. (2026). *Mythos autonomously exploited vulnerabilities that survived 27 years of human review*. https://venturebeat.com/security/mythos-detection-ceiling-security-teams-new-playbook

Scientific American. (2026). *What is Mythos and why are experts worried about Anthropic's AI model*. https://www.scientificamerican.com/article/what-is-mythos-and-why-are-experts-worried-about-anthropics-ai-model/

Schneier on Security. (2026, April). *On Anthropic's Mythos Preview and Project Glasswing*. https://www.schneier.com/blog/archives/2026/04/on-anthropics-mythos-preview-and-project-glasswing.html

Noma Security. (2026). *The Mythos Reality Check: What Does Project Glasswing Mean for CISOs?* https://noma.security/blog/the-mythos-reality-check-what-does-project-glasswing-mean-for-cisos/

SiliconFlow. (2026). *The Best Open Source LLM for Cybersecurity & Threat Analysis in 2026*. https://www.siliconflow.com/articles/en/best-open-source-LLM-for-Cybersecurity-Threat-Analysis

Pinggy. (2026). *Best Open Source Self-Hosted LLMs for Coding in 2026*. https://pinggy.io/blog/best*open*source*self*hosted*llms*for_coding/

DeepSeek. (2025). *DeepSeek Coder: When the Large Language Model Meets Programming*. https://deepseekcoder.github.io/

Qwen Team, Alibaba Cloud. (2024). *Qwen2.5-Coder Technical Report*. https://arxiv.org/html/2409.12186v3

Grand View Research. (2023). *Application Security Testing Market Size Report, 2030*. https://www.grandviewresearch.com/industry-analysis/application-security-testing-market

MarketsandMarkets. (2023). *Cloud Security Posture Management (CSPM) Market — Global Forecast to 2028*.

MarketsandMarkets. (2024). *GRC Platform Market — Global Forecast to 2030*.

IDC. (2024). *Worldwide AI Governance and Responsible AI Software Forecast, 2025–2030*.

Allied Market Research. (2023). *DevSecOps Market by Component and Deployment Mode, 2023–2031*.

MarketsandMarkets. (2024). *Generative AI in Cybersecurity Market — Global Forecast to 2030*.

MarketsandMarkets. (2023). *Multi-Cloud Management Market — Global Forecast to 2028*.

Flexera. (2024). *State of the Cloud Report 2024*. https://info.flexera.com/CM-REPORT-State-of-the-Cloud

OWASP Foundation. (2025). *OWASP Top 10 for Large Language Model Applications v2025*. https://owasp.org/www-project-top-10-for-large-language-model-applications/

ISO/IEC. (2023). *ISO/IEC 42001:2023 — Artificial intelligence — Management system*. https://www.iso.org/standard/81230.html

European Parliament. (2024). *Regulation (EU) 2024/1689 — Artificial Intelligence Act*. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689

NIST. (2023). *AI Risk Management Framework (AI RMF 1.0)*. https://www.nist.gov/system/files/documents/2023/01/26/AI%20RMF%201.0.pdf

NIST. (2024). *Cybersecurity Framework (CSF) 2.0*. https://doi.org/10.6028/NIST.CSWP.29

Monetary Authority of Singapore. (2021). *Technology Risk Management Guidelines*. https://www.mas.gov.sg/regulation/guidelines/technology-risk-management-guidelines

PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard v4.0*. https://www.pcisecuritystandards.org

Center for Internet Security. (2023). *CIS AWS Foundations Benchmark v3.0.0*. https://www.cisecurity.org/benchmark/amazon*web*services

Center for Internet Security. (2023). *CIS Microsoft Azure Foundations Benchmark v2.0.0*. https://www.cisecurity.org/benchmark/azure

Center for Internet Security. (2023). *CIS Google Cloud Computing Foundations Benchmark v2.0.0*. https://www.cisecurity.org/benchmark/google*cloud*computing_platform